

API Security Scan Report

Target: crAPI | Generated: 2026-04-28 18:47:24

Total Checks	Critical	High	Medium	Passed
59	6	3	3	47

Findings

Check	Endpoint	Method	Severity	Detail
BOLA	/workshop/api/shop/orders/{order_id}	GET	CRITICAL	Attacker accessed victim order ID 7 — IDOR confirmed
BOLA	/workshop/api/shop/orders/all	GET	CRITICAL	Attacker retrieved all orders without restriction
BOLA	/identity/api/v2/vehicle/{uuid}/location	GET	CRITICAL	Attacker accessed victim vehicle location: 200 — GPS data exposed
JWT None Algorithm	/identity/api/v2/user/dashboard	GET	CRITICAL	Server accepted token with alg:none — signature verification bypassed
JWT None Algorithm	/workshop/api/shop/products	GET	CRITICAL	Server accepted token with alg:none — signature verification bypassed
JWT None Algorithm	/identity/api/v2/vehicle/vehicles	GET	CRITICAL	Server accepted token with alg:none — signature verification bypassed
Rate Limit Bypass	/identity/api/auth/login	POST	HIGH	Sent 20 requests, never got 429. Statuses: [401]
SSRF	/workshop/api/merchant/contact_mechanic	POST	HIGH	Server attempted to fetch http://127.0.0.1 — SSRF confirmed (connection failed but request was made)
SSRF	/workshop/api/merchant/contact_mechanic	POST	HIGH	Server attempted to fetch http://169.254.169.254/latest/meta-data/ — SSRF confirmed (connection failed but request was made)
Parameter Tampering	/identity/api/v2/user/dashboard	GET	MEDIUM	Server accepted tampered payload and returned 200
Info Leak (500)	/workshop/api/shop/orders	GET	MEDIUM	Returns 500 without auth — server error exposed
Excessive Data Exposure	/identity/api/v2/user/dashboard	GET	MEDIUM	Internal field 'role' exposed in response
Insecure Endpoint	/identity/api/v2/user/dashboard	GET	PASS	Correctly returned 404 without token
Insecure Endpoint	/workshop/api/shop/products	GET	PASS	Correctly returned 401 without token
Insecure Endpoint	/workshop/api/shop/orders	GET	PASS	Correctly returned 500 without token
Insecure Endpoint	/community/api/v2/community/posts/recent	GET	PASS	Correctly returned 401 without token
Insecure Endpoint	/workshop/api/mechanic	GET	PASS	Correctly returned 401 without token
Insecure Endpoint	/identity/api/v2/vehicle/vehicles	GET	PASS	Correctly returned 401 without token

Insecure Endpoint	/workshop/api/merchant/contact_mechanic	POST	PASS	Correctly returned 401 without token
Insecure Endpoint	/workshop/api/shop/orders/all	GET	PASS	Correctly returned 401 without token
Insecure Endpoint	/identity/api/v2/admin/users	GET	PASS	Correctly returned 401 without token
Insecure Endpoint	/workshop/api/mechanic/mechanic_report	GET	PASS	Correctly returned 401 without token
Broken Authentication	/identity/api/v2/user/dashboard	GET	PASS	Correctly rejected expired_token with 404
Broken Authentication	/identity/api/v2/user/dashboard	GET	PASS	Correctly rejected malformed_token with 404
Broken Authentication	/identity/api/v2/user/dashboard	GET	PASS	Correctly rejected empty_bearer with 404
Broken Authentication	/workshop/api/shop/products	GET	PASS	Correctly rejected expired_token with 401
Broken Authentication	/workshop/api/shop/products	GET	PASS	Correctly rejected malformed_token with 401
Broken Authentication	/workshop/api/shop/products	GET	PASS	Correctly rejected empty_bearer with 401
Broken Authentication	/workshop/api/shop/orders	GET	PASS	Correctly rejected expired_token with 500
Broken Authentication	/workshop/api/shop/orders	GET	PASS	Correctly rejected malformed_token with 500
Broken Authentication	/workshop/api/shop/orders	GET	PASS	Correctly rejected empty_bearer with 500
Broken Authentication	/community/api/v2/community/posts/recent	GET	PASS	Correctly rejected expired_token with 401
Broken Authentication	/community/api/v2/community/posts/recent	GET	PASS	Correctly rejected malformed_token with 401
Broken Authentication	/community/api/v2/community/posts/recent	GET	PASS	Correctly rejected empty_bearer with 401
Broken Authentication	/workshop/api/mechanic	GET	PASS	Correctly rejected expired_token with 401
Broken Authentication	/workshop/api/mechanic	GET	PASS	Correctly rejected malformed_token with 401
Broken Authentication	/workshop/api/mechanic	GET	PASS	Correctly rejected empty_bearer with 401
Broken Authentication	/identity/api/v2/vehicle/vehicles	GET	PASS	Correctly rejected expired_token with 401
Broken Authentication	/identity/api/v2/vehicle/vehicles	GET	PASS	Correctly rejected malformed_token with 401
Broken Authentication	/identity/api/v2/vehicle/vehicles	GET	PASS	Correctly rejected empty_bearer with 401
Broken Authentication	/workshop/api/merchant/contact_mechanic	POST	PASS	Correctly rejected expired_token with 401
Broken Authentication	/workshop/api/merchant/contact_mechanic	POST	PASS	Correctly rejected malformed_token with 401
Broken Authentication	/workshop/api/merchant/contact_mechanic	POST	PASS	Correctly rejected empty_bearer with 401
Broken Authentication	/workshop/api/shop/orders/all	GET	PASS	Correctly rejected expired_token with 401
Broken Authentication	/workshop/api/shop/orders/all	GET	PASS	Correctly rejected malformed_token with 401
Broken Authentication	/workshop/api/shop/orders/all	GET	PASS	Correctly rejected empty_bearer with 401
Broken Authentication	/identity/api/v2/admin/users	GET	PASS	Correctly rejected expired_token with 401

Broken Authentication	/identity/api/v2/admin/users	GET	PASS	Correctly rejected malformed_token with 401
Broken Authentication	/identity/api/v2/admin/users	GET	PASS	Correctly rejected empty_bearer with 401
Broken Authentication	/workshop/api/mechanic/mechanic_report	GET	PASS	Correctly rejected expired_token with 401
Broken Authentication	/workshop/api/mechanic/mechanic_report	GET	PASS	Correctly rejected malformed_token with 401
Broken Authentication	/workshop/api/mechanic/mechanic_report	GET	PASS	Correctly rejected empty_bearer with 401
Parameter Tampering	/workshop/api/merchant/contact_mechanic	POST	PASS	Returned 465 for tampered request
Mass Assignment	/identity/api/auth/signup	POST	PASS	Extra fields ignored — admin role not granted
Mass Assignment	/identity/api/v2/admin/users	GET	PASS	Mass-assigned account accessed admin endpoint: 404
Excessive Data Exposure	/workshop/api/shop/products	GET	PASS	No sensitive fields detected in response
Excessive Data Exposure	/identity/api/v2/vehicle/vehicles	GET	PASS	No sensitive fields detected in response
Excessive Data Exposure	/workshop/api/shop/orders/all	GET	PASS	No sensitive fields detected in response
Excessive Data Exposure	/community/api/v2/community/posts/recent	GET	PASS	No sensitive fields detected in response